Site vitrine Nhill — mise en service et base de données

English version: README.en.md

Ce dossier contient le site public de Nhill et le petit service qui reçoit ses formulaires (démonstration, programme pilote, partenariat, contact). Il est **indépendant** de l'application Nhill : autre base de données, autres rôles, autres secrets. Une fuite du site ne donne aucun accès aux données des commerces.

Élément	Emplacement	Rôle
Pages générées	`index.html`, `pages/`, `en/`, `404.html`, `sitemap.xml`, `robots.txt`	HTML statique servi tel quel
Sources des pages	`src/pages/fr/*.html`, `src/pages/en/*.html`	contenu ; régénérer avec `tools/build_site.py`
Styles, script, images	`assets/`	CSS3, JavaScript sans dépendance, WebP, polices locales
Configuration publique	`config/site.json`	trois valeurs publiques seulement (voir § 3)
Backend des formulaires	`backend/`	Python 3 standard (+ psycopg 3 pour PostgreSQL)
Déploiement	`backend/deploy/`	unité systemd, purge quotidienne, extrait Caddyfile
Outils	`tools/`	génération, contrôle, configuration publique

1. Principe de sécurité

- Le navigateur ne voit **jamais** l'adresse ni le mot de passe de la base. Le JavaScript envoie le formulaire en JSON à `SITE_API_BASE_URL/api/forms/<type>` ; seul le backend, sur le serveur, se connecte à la base.
- Le backend écoute sur `127.0.0.1:8090` ; seul le proxy TLS (Caddy) est exposé.
- Le rôle de base utilisé par le service web peut **insérer** des demandes, pas les relire, les modifier ni les supprimer. Une compromission du service ne permet donc pas d'exfiltrer les demandes déjà reçues. La lecture, l'export et l'effacement passent par la commande de maintenance, avec un autre rôle.
- Protections des formulaires : validation côté navigateur **et** côté serveur, liste blanche des origines (CORS), type `application/json` obligatoire, corps limité à 16 Ko, champ piège (honeypot), délai minimal de remplissage, limite par adresse IP et par formulaire (5/heure par défaut) et limite globale par jour (300), caractères de contrôle supprimés, consentement explicite à la politique de confidentialité, consentement marketing séparé et non coché par défaut.
- Minimisation : seuls les champs du formulaire concerné sont gardés ; l'adresse IP n'est jamais stockée, seulement une empreinte HMAC (clé `SITE_IP_HASH_SALT`) effacée après 30 jours ; les demandes sont supprimées après 365 jours (purge quotidienne).
- Les journaux du service ne contiennent ni adresse IP ni contenu de formulaire.

Ces mesures réduisent les risques ; elles ne rendent pas le service invulnérable. Gardez le système et Python à jour, et relisez § 9.

2. Démarrage rapide en développement (SQLite)

```
cd website/backend
export SITE_IP_HASH_SALT="$(openssl rand -hex 32)"
export SITE_ALLOWED_ORIGINS=http://localhost:8000
export SITE_SQLITE_PATH=./data/site.sqlite3          # dossier ignoré par git
python3 -m nhill_site.cli init
python3 -m nhill_site.server &                        # http://127.0.0.1:8090
cd .. && SITE_API_BASE_URL=http://127.0.0.1:8090 python3 tools/configure_site.py
python3 -m http.server 8000                           # http://localhost:8000
```

Remettez `config/site.json` dans son état versionné avant de valider (`git checkout website/config/site.json`).

Tests : `cd website/backend && python3 -m unittest discover -s tests -v` (13 tests, base SQLite jetable). Contrôle des pages : `python3 website/tools/check_site.py website`.

3. Variables de configuration

3.1 Configuration publique (`config/site.json`, téléchargée par chaque visiteur)

Variable de déploiement	Clé JSON	Exemple	Effet
`SITE_PUBLIC_BASE_URL`	`publicBaseUrl`	`https://www.exemple.cd`	balises canoniques, hreflang, sitemap
`SITE_API_BASE_URL`	`apiBaseUrl`	`https://www.exemple.cd`	adresse du backend ; vide = les formulaires affichent « non connecté »
`SITE_CONTACT_EMAIL`	`contactEmail`	`contact@exemple.cd`	adresse affichée si les formulaires ne sont pas connectés

`python3 website/tools/configure_site.py` écrit ces trois valeurs depuis l'environnement et refuse toute autre clé, toute adresse non `https://` (sauf `localhost`) et tout identifiant dans une URL. Après un changement de `SITE_PUBLIC_BASE_URL`, régénérez les pages : `python3 website/tools/build_site.py`.

3.2 Configuration du backend (fichier `/etc/nhill-site/site.env`, jamais public)

Modèle complet : `backend/.env.example` (valeurs fictives seulement).

Variable	Défaut	Description
`SITE_DATABASE_ENGINE`	`sqlite`	`sqlite` ou `postgresql`
`SITE_SQLITE_PATH`	`data/site.sqlite3`	fichier SQLite (créé en mode 600, dossier en 700)
`SITE_DATABASE_HOST`	`127.0.0.1`	hôte PostgreSQL
`SITE_DATABASE_PORT`	`5432`	port PostgreSQL
`SITE_DATABASE_NAME`	`nhill_site`	base dédiée au site
`SITE_DATABASE_USER`	`nhill_site_app`	rôle du service web (insertion seule)
`SITE_DATABASE_PASSWORD`	*(aucun)*	obligatoire avec PostgreSQL
`SITE_DATABASE_SSLMODE`	`prefer`	`disable`, `prefer`, `require`, `verify-full`

Variable	Défaut	Description
`SITE_MAINTENANCE_DATABASE_USER` / `_PASSWORD`	—	rôle de la commande de maintenance
`SITE_LISTEN_HOST` / `SITE_LISTEN_PORT`	`127.0.0.1` / `8090`	écoute du service
`SITE_ALLOWED_ORIGINS`	*(aucun)*	origines autorisées, séparées par des virgules ; obligatoire
`SITE_TRUST_PROXY`	`0`	`1` derrière Caddy : utilise l'entrée de droite de `X-Forwarded-For`
`SITE_IP_HASH_SALT`	*(aucun)*	≥ 32 caractères, `openssl rand -hex 32` ; obligatoire
`SITE_RETENTION_DAYS`	`365`	conservation des demandes
`SITE_IP_RETENTION_DAYS`	`30`	conservation de l'empreinte IP
`SITE_MIN_FILL_MS`	`3000`	délai minimal de remplissage (anti-robots)
`SITE_RATE_PER_HOUR`	`5`	envois par IP, par formulaire et par heure
`SITE_RATE_PER_DAY_GLOBAL`	`300`	envois par jour, tous visiteurs
`SITE_PUBLIC_BASE_URL`, `SITE_CONTACT_EMAIL`	—	informations, identiques à § 3.1
`SITE_NOTIFY_EMAIL`, `SITE_SMTP_HOST/PORT/USER/PASSWORD/FROM`	—	notification facultative (type et identifiant seulement, pas le contenu)
`SITE_ENV_FILE`	—	fichier de variables à charger (refusé s'il est lisible par d'autres que son propriétaire)

Le service refuse de démarrer si une valeur obligatoire manque ou est trop faible.

4. Base PostgreSQL dédiée

SQLite suffit pour un site à faible trafic sur un seul serveur. PostgreSQL est recommandé si la base est sur une autre machine, si plusieurs instances tournent ou si vos sauvegardes sont déjà organisées autour de PostgreSQL. Versions testées : PostgreSQL 16 (localement et en CI) ; le schéma n'utilise rien de propre à une version récente.

4.1 Créer la base et les rôles (une fois, en superutilisateur)

```
sudo apt install postgresql python3-psycopg
cd website/backend/schema/postgresql
OWNER_PW="$(openssl rand -base64 30)"; APP_PW="$(openssl rand -base64 30)";
MAINT_PW="$(openssl rand -base64 30)"
sudo -u postgres psql -v ON_ERROR_STOP=1 \
     -v owner_pw="$OWNER_PW" -v app_pw="$APP_PW" -v maint_pw="$MAINT_PW" -f 000_roles.sql
```

Rangez les trois mots de passe dans votre coffre de secrets ; ne les écrivez dans aucun fichier versionné. `000_roles.sql` crée :

Rôle	Droits	Utilisé par
`nhill_site_owner`	propriétaire de la base et du schéma `site`	migrations uniquement
`nhill_site_app`	`CONNECT` ; `INSERT` sur `submissions` ; `SELECT, INSERT, UPDATE` sur `rate_limits`	service web
`nhill_site_maint`	`CONNECT` ; `SELECT, UPDATE, DELETE` sur `submissions` ; `SELECT, DELETE` sur `rate_limits`	commande de maintenance, purge

`PUBLIC` perd ses droits sur la base et sur le schéma `public`.

4.2 Appliquer le schéma (migrations)

```
PGPASSWORD="$OWNER_PW" psql "host=127.0.0.1 dbname=nhill_site user=nhill_site_owner
sslmode=require" \
     -v ON_ERROR_STOP=1 -f 001_init.sql
```

Les fichiers `schema/postgresql/NNN_*.sql` s'appliquent dans l'ordre, une seule fois, avec le rôle propriétaire. Une future migration sera un nouveau fichier `002_…sql` ; on ne modifie jamais un fichier déjà appliqué en production. `001_init.sql` est idempotent (`IF NOT EXISTS`) et transactionnel.

4.3 Configurer et tester la connexion

Dans `/etc/nhill-site/site.env` :

```
SITE_DATABASE_ENGINE=postgresql
SITE_DATABASE_HOST=127.0.0.1
SITE_DATABASE_PORT=5432
SITE_DATABASE_NAME=nhill_site
SITE_DATABASE_USER=nhill_site_app
SITE_DATABASE_PASSWORD=<APP_PW>
SITE_DATABASE_SSLMODE=require
SITE_MAINTENANCE_DATABASE_USER=nhill_site_maint
SITE_MAINTENANCE_DATABASE_PASSWORD=<MAINT_PW>
```

```
sudo -u nhill-site env SITE_ENV_FILE=/etc/nhill-site/site.env python3 -m nhill_site.cli check
# → connexion OK (postgresql), 0 demande(s) enregistrée(s)
curl -s http://127.0.0.1:8090/api/health        # → {"status": "ok"}
```

Vérification des privilèges (doit échouer avec « permission denied ») :

```
PGPASSWORD="$APP_PW" psql "host=127.0.0.1 dbname=nhill_site user=nhill_site_app" -c 'SELECT *
FROM submissions'
```

4.4 TLS vers la base

- Base sur la même machine : connexion locale, `sslmode=prefer` acceptable.
- Base sur une autre machine : `sslmode=verify-full` avec le certificat de l'autorité dans `~nhill-site/.postgresql/root.crt` (ou `PGSSLROOTCERT`), et dans `pg_hba.conf` une règle `hostssl nhill_site nhill_site_app <ip-du-serveur-web>/32 scram-sha-256`. N'ouvrez pas le port 5432 à Internet.

4.5 Sauvegarde et restauration

```
# sauvegarde chiffrée quotidienne (exemple)
pg_dump -Fc "host=127.0.0.1 dbname=nhill_site user=nhill_site_owner" \
  | gpg --encrypt --recipient <clé> > nhill_site-$(date +%F).dump.gpg
# restauration dans une base vide créée par 000_roles.sql
gpg --decrypt nhill_site-AAAA-MM-JJ.dump.gpg \
  | pg_restore --no-owner --role=nhill_site_owner -d "host=127.0.0.1 dbname=nhill_site
user=nhill_site_owner"
```

SQLite : `sqlite3 /var/lib/nhill-site/site.sqlite3 ".backup '/sauvegardes/site-$(date +%F).sqlite3'"` puis chiffrement du fichier. Les sauvegardes contiennent des données personnelles : même durée de conservation que la base (365 jours), accès restreint. Testez une restauration au moins une fois par trimestre.

4.6 Rotation des identifiants

1. `ALTER ROLE nhill_site_app PASSWORD '<nouveau>';` (en superutilisateur ou propriétaire) ;
2. mettre à jour `SITE_DATABASE_PASSWORD` dans `/etc/nhill-site/site.env` ;
3. `sudo systemctl restart nhill-site` puis `python3 -m nhill_site.cli check`.

Même démarche pour `nhill_site_maint`. Changez aussi `SITE_IP_HASH_SALT` en cas de fuite présumée (conséquence : les compteurs de limitation repartent à zéro). Effectuez une rotation immédiate si un secret a pu être exposé (journal, capture d'écran, dépôt git).

5. Mise en production (Debian 12/13, Ubuntu 22.04/24.04)

```
sudo useradd --system --home /var/lib/nhill-site --shell /usr/sbin/nologin nhill-site
sudo install -d -o nhill-site -g nhill-site -m 700 /var/lib/nhill-site
sudo install -d -m 750 -g nhill-site /etc/nhill-site
sudo install -m 600 -o nhill-site -g nhill-site website/backend/.env.example /etc/nhill-
site/site.env   # puis éditer
sudo cp -r website/backend /opt/nhill-site
sudo cp website/backend/deploy/nhill-site*.service website/backend/deploy/nhill-site-
purge.timer /etc/systemd/system/
sudo systemctl daemon-reload
sudo systemctl enable --now nhill-site nhill-site-purge.timer
# site statique
SITE_PUBLIC_BASE_URL=https://www.exemple.cd SITE_API_BASE_URL=https://www.exemple.cd \
SITE_CONTACT_EMAIL=contact@exemple.cd python3 website/tools/configure_site.py
python3 website/tools/build_site.py
sudo install -d /var/www/nhill-site
sudo rsync -a --delete --exclude backend --exclude src --exclude tools --exclude 'README*'
website/ /var/www/nhill-site/
# proxy TLS : adapter le nom de domaine dans l'extrait puis l'inclure dans
/etc/caddy/Caddyfile
sudo cp website/backend/deploy/Caddyfile.site /etc/caddy/nhill-site.caddy
```

L'extrait Caddy sert le site, transmet `/api/*` au backend, ajoute HSTS et une politique de sécurité du contenu (CSP) stricte, et refuse les fichiers sources ou de configuration. `scripts/build-website.sh` produit une archive `dist/website/nhill-website-<version>.tar.gz` (sans `.env` ni base) avec ses sommes SHA-256.

Développement et production : différences

	Développement	Production
Base	SQLite dans `website/backend/data/`	SQLite `/var/lib/nhill-site/` ou PostgreSQL dédié
Origines	`http://localhost:8000`	`https://www.<domaine>` uniquement
`SITE_TRUST_PROXY`	`0`	`1` (derrière Caddy)
TLS	aucun	Caddy (certificat automatique), `sslmode=require` ou `verify-full`
Secrets	variables du terminal	`/etc/nhill-site/site.env` (600, propriétaire `nhill-site`) ou gestionnaire de secrets

6. Exploitation des demandes

```
cd /opt/nhill-site
alias site-cli='sudo -u nhill-site env SITE_ENV_FILE=/etc/nhill-site/site.env python3 -m
nhill_site.cli'
site-cli stats                       # nombre par formulaire et statut
site-cli list --kind pilot           # liste (sans le message)
site-cli show <id>                   # détail
site-cli set-status <id> contacted   # new, contacted, qualified, closed
site-cli export --email x@y.cd       # demande d'accès d'une personne (JSON)
site-cli delete --email x@y.cd       # demande d'effacement
site-cli unsubscribe --email x@y.cd  # retrait du consentement marketing
site-cli purge                       # durée de conservation (lancée chaque jour par le timer)
```

Répondez aux demandes d'accès ou d'effacement dans les délais prévus par la politique de confidentialité ; consignez la réponse.

7. Contrôles automatiques

- `website/tools/check_site.py` : liens internes, `alt`, titres, descriptions, `lang`, paires FR/EN, absence de motifs de secrets dans les fichiers publics.
- `website/tools/build_site.py --check` : les pages générées correspondent aux sources.
- Tests du backend sur SQLite (local, CI) et sur PostgreSQL 16 avec les vrais rôles (job `site-backend-postgresql` de `.github/workflows/docs-website.yml`).

8. Dépannage

Symptôme	Cause probable	Action
Formulaire : « Ce formulaire n'est pas encore relié à notre serveur »	`apiBaseUrl` vide	`configure_site.py` avec `SITE_API_BASE_URL`, redéployer `config/site.json`
Réponse 403	origine absente de `SITE_ALLOWED_ORIGINS`	ajouter l'origine exacte (schéma + hôte, sans `/` final)
Réponse 429	limite atteinte	attendre (`Retry-After`) ; ajuster `SITE_RATE_PER_HOUR` avec prudence

Symptôme	Cause probable	Action
Réponse 422	champ invalide (nom du champ dans `field`)	corriger la saisie
Toutes les demandes d'un même visiteur bloquées derrière Caddy	`SITE_TRUST_PROXY=0` : l'IP vue est celle du proxy	`SITE_TRUST_PROXY=1`
`psycopg 3 absent`	paquet manquant	`sudo apt install python3-psycopg`
`password authentication failed`	mot de passe ou `pg_hba.conf`	vérifier le fichier d'environnement et la règle `scram-sha-256`
`permission denied for table submissions`	normal pour une lecture ; anormal pour une insertion	réappliquer `001_init.sql` (droits)
`SITE_IP_HASH_SALT doit contenir au moins 32 caractères`	valeur absente ou courte	`openssl rand -hex 32`
`journalctl -u nhill-site` vide	service non démarré	`systemctl status nhill-site`

9. Avant d'ouvrir les formulaires au public

- ☐ Politique de confidentialité et mentions légales complétées (identité de l'éditeur, contact, hébergeur) et validées par un juriste — voir `legal/`.
- ☐ Formalités auprès de l'autorité de protection des données en RDC vérifiées (voir `docs/fr/parametres-legaux.md`).
- ☐ `SITE_IP_HASH_SALT` et mots de passe générés pour ce serveur, rangés dans un coffre.
- ☐ Sauvegarde chiffrée et restauration testées.
- ☐ Envoi de test de chaque formulaire, puis `cli delete` de ces essais.
- ☐ Une personne désignée lit les demandes et répond.